

**CORSO I.F.T.S.
SPECIALIZZAZIONE IN TECNICHE PER LA SICUREZZA
DELLE RETI E DEI SISTEMI**

CYBER SECURITY SPECIALIST 3

PROJECT WORK

**Cybersecurity nei Siti E-Commerce:
Analisi delle Minacce e Difesa tramite Web Application Firewall**

**di Iacopo Libero
Bernabei**

Anno 2024/2025

INDICE

Capitolo 1 – Introduzione.....	2
1.1 Il contesto della sicurezza informatica oggi.....	2
1.2 L'importanza della cybersecurity nei siti e-commerce.....	2
1.3 Obiettivi della tesina e metodologia seguita.....	2
Capitolo 2 – Fondamenti di sicurezza informatica.....	2
2.1 Definizione di minaccia, vulnerabilità e rischio.....	2
2.2 I principi fondamentali della sicurezza informatica (CIA).....	3
2.3 Classificazione degli attacchi alle applicazioni web.....	3
Capitolo 3 – Analisi delle minacce e dei rischi nei siti e-commerce.....	4
3.1 Minacce comuni ai siti e-commerce.....	4
3.2 Vulnerabilità sfruttate dagli attaccanti.....	4
3.3 Valutazione dei rischi.....	5
Capitolo 4 – Contromisure e strumenti di difesa.....	6
4.1 Introduzione ai Web Application Firewall (WAF).....	6
4.2 Cloudflare, un esempio pratico di WAF.....	7
4.3 Tecniche aggiuntive di protezione.....	8
4.4 Politiche organizzative di sicurezza.....	10
Capitolo 5 – Caso studio: analisi cliente dell'azienda ospitante.....	12
5.1 Presentazione dell'azienda e del sistema informativo.....	12
5.2 Analisi dell'architettura web: componenti e servizi esposti.....	12
5.3 Identificazione di minacce dell'infrastruttura del cliente.....	13
5.4 Contromisure adottate o consigliate nel VA/PT.....	15
Capitolo 6 – Conclusioni.....	16
Capitolo 7 – Esperienza del tirocinio e valutazione del percorso formativo.....	17
7.1 Attività svolte durante lo stage.....	17
7.2 Conoscenze e competenze acquisite in aula e in azienda.....	18
7.3 Valutazione personale del corso IFTS Cyber Security Specialist 3.....	18
7.4 Impatto del corso sul mio percorso professionale.....	19
Capitolo 8 – Bibliografia e sitografia.....	19

Capitolo 1 – Introduzione

1.1 Il contesto della sicurezza informatica oggi

La crescente digitalizzazione ha reso la sicurezza informatica un tema centrale.

Le minacce cyber, sempre più sofisticate, colpiscono aziende e cittadini, generando conseguenze non solo tecniche, ma anche economiche, legali e reputazionali. Proteggere dati e sistemi informativi è oggi una priorità imprescindibile e una sfida centrale per ogni realtà che opera nel contesto digitale moderno.

1.2 L'importanza della cybersecurity nei siti e-commerce

I siti e-commerce, esposti costantemente su internet (24/7) e gestori di dati sensibili e transazioni online, sono bersagli privilegiati per gli attacchi informatici.

Una violazione può causare gravi danni economici e perdita di fiducia da parte dei clienti.

Per questo motivo, è fondamentale adottare un approccio proattivo alla sicurezza, attraverso l'identificazione delle minacce, la gestione delle vulnerabilità e l'implementazione di contromisure tecniche e organizzative efficaci.

1.3 Obiettivi della tesina e metodologia seguita

Questa tesina analizza le principali minacce ai siti e-commerce e le possibili contromisure, con un focus sui WAF.

Verrà esaminato un caso reale dell'azienda presso cui è stato svolto lo stage, valutando la sicurezza dell'e-commerce di un cliente della stessa.

L'approccio adottato combina analisi teorica, osservazione diretta e confronto con esperti, seguendo una struttura “a imbuto” dal generale al caso concreto.

Capitolo 2 – Fondamenti di sicurezza informatica

2.1 Definizione di minaccia, vulnerabilità e rischio

Minaccia: potenziale di violazione della sicurezza, che esiste quando c'è una circostanza, una capacità, un'azione o un evento che potrebbe violare la sicurezza e causare danni.

Vulnerabilità: difetto o debolezza nella progettazione, nell'implementazione o nel funzionamento e nella gestione di un sistema che potrebbe essere sfruttato per violare l'integrità o la politica di sicurezza del sistema.

Rischio= $f(\text{Minaccia}, \text{Vulnerabilità}, \text{Impatto})$: Aspettativa di perdita espressa come probabilità che una particolare minaccia sfrutti una particolare vulnerabilità con una particolare conseguenza.

2.2 I principi fondamentali della sicurezza informatica (CIA)

La triade CIA rappresenta i tre parametri fondamentali per classificare la sicurezza di un sistema:

Confidentiality (Riservatezza): Garantisce che solo chi è autorizzato possa accedere alle informazioni.

- Include l'uso di crittografia per proteggere i dati in transito e a riposo.
- Protegge la privacy e limita l'accesso alle risorse sensibili.

Integrity (Integrità): Assicura che i dati non vengano alterati in modo non autorizzato.

- Utilizza strumenti come funzioni di hash e firme digitali per verificare che i dati non siano stati modificati.

Availability (Disponibilità): Garantisce che il sistema e le informazioni siano accessibili quando necessario.

- Richiede ridondanza, backup e infrastrutture resilienti per prevenire downtime.

2.3 Classificazione degli attacchi alle applicazioni web

[L'OWASP Top 10](#) è una guida pubblicata dall'organizzazione internazionale no-profit OWASP che elenca le 10 principali vulnerabilità di sicurezza per le applicazioni web, tra queste figurano:

- Injection (es. SQL Injection)
- Broken Authentication
- Sensitive Data Exposure
- Cross-Site Scripting (XSS)
- Security Misconfiguration

Comprendere queste categorie è essenziale per progettare web app e infrastrutture sicure ed efficaci contro le possibili minacce.

Capitolo 3 – Analisi delle minacce e dei rischi nei siti e-commerce

3.1 Minacce comuni ai siti e-commerce

I siti e-commerce sono costantemente esposti (24/7) a diverse tipologie di minacce informatiche, entriamo nel dettaglio delle più comuni

3.1.1 SQL Injection

Consente a un attaccante di “iniettare” delle query SQL per accedere, modificare o cancellare dati sensibili nel database.

Spesso è causata dalla mancanza di validazione degli input utente.

3.1.2 Cross-Site Scripting (XSS)

Permette l’inserimento di codice JavaScript malevolo all’interno delle pagine web, con il fine di rubare dati utente o sessioni. Può avere impatti gravi sulla fiducia dei clienti.

3.1.3 Attacchi DDoS

Sovraccaricano il sito utilizzando una *botnet*, quindi una grande capacità di calcolo così da causare disservizi, perdita di vendite e danni reputazionali.

3.1.4 Phishing e social engineering

Tecniche usate per ingannare utenti o operatori e ottenere credenziali o dati riservati, sfruttando la componente umana come punto debole.

3.2 Vulnerabilità sfruttate dagli attaccanti

Le vulnerabilità nei siti e-commerce rappresentano punti deboli che gli attaccanti possono sfruttare per compromettere dati e sistemi.

Molte derivano da errori umani, configurazioni errate o mancanza di aggiornamenti.

3.2.1 Errori di configurazione

Configurazioni errate di server, database o CMS (es. directory esposte, credenziali di default) possono offrire accesso involontario agli attaccanti.

3.2.2 *Input non validati*

L'assenza di controlli sui dati inseriti dagli utenti rappresenta una delle cause principali di exploit, come SQL injection e XSS.

3.2.3 *Aggiornamenti mancanti*

L'uso di software obsoleti o plugin non aggiornati espone il sito a vulnerabilità note (database [MITRE](#)), già sfruttate in attacchi automatizzati.

3.3 *Valutazione dei rischi*

Una fase fondamentale è la valutazione dei rischi, perché consente di individuare le vulnerabilità più critiche e stabilire le priorità di intervento in base alla probabilità e all'impatto degli attacchi.

3.3.1 *Probabilità di attacco*

La probabilità che un attacco abbia successo dipende da due fattori: le capacità dell'attaccante (competenze, motivazione, risorse, dimensioni del gruppo) e la facilità con cui può individuare e sfruttare una vulnerabilità (visibilità, complessità tecnica).

Più l'attaccante è esperto e motivato, più alta sarà la probabilità di attacco.

3.3.2 *Impatto potenziale*

Un attacco può compromettere la riservatezza, l'integrità o la disponibilità dei dati e dei servizi, mentre a livello aziendale, può generare danni economici, perdite di reputazione, sanzioni legali o violazioni della privacy.

3.3.3 *Strategie di risposta*

Le principali strategie di gestione del rischio sono:

- Mitigare (con contromisure tecniche e organizzative)
- Evitare (rimuovendo la funzione a rischio)
- Trasferire (es. assicurazioni)
- Accettare (quando il rischio è limitato)

L'approccio consigliato è *defense in depth*: protezioni a più livelli che rallentano o impediscono un attacco anche in caso di violazione di un singolo componente.

Capitolo 4 – Contromisure e strumenti di difesa

4.1 Introduzione ai Web Application Firewall (WAF)

4.1.1 Cos'è un WAF

Un *Web Application Firewall* (WAF) è un sistema di sicurezza progettato per proteggere le applicazioni web filtrando e monitorando il traffico HTTP tra l'utente e il server.

A differenza dei *firewall* tradizionali, che operano a livello di rete e bloccano traffico non autorizzato in base a porte, protocolli o indirizzi IP, un WAF è in grado di analizzare il contenuto delle richieste e risposte HTTP e bloccare comportamenti potenzialmente dannosi specifici delle applicazioni web.

Il suo scopo principale è impedire attacchi comuni come *SQL injection*, *cross-site scripting* (XSS), *file inclusion*, *cross-site request forgery* (CSRF) e altre vulnerabilità elencate nell'OWASP Top 10.

I WAF vengono utilizzati non solo per proteggere siti e-commerce, ma anche portali bancari, piattaforme SaaS, sistemi sanitari online e ogni tipo di applicazione che gestisca dati sensibili.

4.1.2 Come funziona

Un WAF si interpone tra l'utente e l'applicazione web, agendo come un *reverse proxy*: riceve le richieste in arrivo, le analizza in tempo reale e decide se inoltrarle, modificarle o bloccarle in base a regole di sicurezza predefinite.

Queste regole possono essere statiche (es. *blacklist* di IP, pattern noti di attacco) oppure dinamiche e adattive, aggiornate costantemente tramite *threat intelligence* o meccanismi di apprendimento automatico (es. *Machine Learning*).

Molti WAF supportano l'ispezione profonda dei pacchetti (*Deep Packet Inspection*), il tracciamento delle sessioni e il controllo dei cookie.

Alcuni includono anche funzionalità di rate limiting, blocco geografico, protezione da bot e CAPTCHA per distinguere utenti reali da automatismi dannosi.

In scenari avanzati, il WAF può essere integrato con SIEM (*Security Information and Event Management*) o strumenti di risposta automatica per agire in tempo reale sulla base degli eventi.

4.1.3 WAF basati su cloud vs on-premise

Esistono due principali modalità di implementazione dei WAF: *cloud-based* e *on-premise*.

- WAF *cloud-based*:

Questi WAF sono forniti come servizio (*WAF-as-a-Service*) da provider come Cloudflare, AWS, Microsoft Azure o Imperva.

Sono facili da configurare, non richiedono hardware locale, offrono aggiornamenti automatici e scalabilità elevata.

Tuttavia, possono presentare minori possibilità di personalizzazione e, in alcuni casi, problemi di latenza o dipendenza da un fornitore terzo.

Spesso i *WAF-as-a-service* sono parte integrante di un servizio CDN (*Content Delivery Network*).

- WAF *on-premise*:

Installati localmente nei data center dell'organizzazione o in macchine virtuali, questi WAF offrono il massimo controllo su configurazioni, log e regole di filtraggio.

Sono preferiti in ambienti ad alta sicurezza, dove è necessario mantenere i dati sensibili internamente o dove le policy di compliance impongono restrizioni sull'uso di servizi cloud.

4.2 Cloudflare, un esempio pratico di WAF

Cloudflare è uno dei fornitori di servizi di sicurezza web più diffusi al mondo, noto per offrire una protezione WAF, integrata all'interno dei servizi CDN, potente e facilmente accessibile tramite la propria rete distribuita a livello globale.

Il WAF di Cloudflare opera a livello di edge, ossia sui server di frontiera della rete, prima che il traffico raggiunga l'infrastruttura dell'applicazione.

Una delle funzionalità chiave del WAF di Cloudflare è l'aggiornamento automatico delle regole di protezione, che si adatta continuamente alle nuove minacce identificate a livello globale e alla reputazione negativa degli indirizzi IP di origine.

Il sistema si basa sia su un insieme di regole gestite (*Managed Rules*) che su regole

personalizzabili, che consentono all'amministratore di configurare eccezioni, whitelist o comportamenti specifici.

Cloudflare protegge automaticamente contro le principali vulnerabilità dell'OWASP Top 10, implementa meccanismi avanzati di rate limiting, challenge (es. CAPTCHA o JavaScript challenge) e mitigazione automatica di attacchi DDoS.

Un vantaggio significativo è l'integrazione con altri servizi come CDN, DNS sicuro, e *Zero Trust access*, permettendo di costruire una difesa unificata ed efficiente.

4.3 Tecniche aggiuntive di protezione

Oltre all'impiego dei WAF, un'efficace strategia di difesa per le applicazioni web richiede l'adozione di ulteriori tecniche di protezione.

Queste misure contribuiscono a rafforzare la sicurezza sia dal lato applicativo che infrastrutturale, mitigando le vulnerabilità più comuni e migliorando la resilienza complessiva del sistema.

4.3.1 Validazione dell'input e sicurezza del codice

Una delle principali cause di attacchi come SQL Injection o XSS è l'assenza di una corretta validazione dei dati inseriti dagli utenti. La validazione dell'input deve essere implementata sia lato client che soprattutto lato server, includendo:

- Controlli di tipo, lunghezza e formato dei dati.
- Sanitizzazione dei caratteri speciali.
- Uso di query parametriche per evitare l'iniezione di codice nei database.

Inoltre, scrivere codice sicuro implica seguire buone pratiche di sviluppo come la programmazione difensiva, la gestione sicura degli errori (evitando di mostrare stack trace o messaggi tecnici all'utente), e l'uso di librerie aggiornate e mantenute.

4.3.2 Cifratura HTTPS/TLS

L'adozione obbligatoria di HTTPS, con certificati validi (emessi da CA affidabili) e configurazioni TLS aggiornate, è oggi un requisito minimo per qualsiasi sito web professionale.

L'uso di tecniche come HSTS (HTTP Strict Transport Security) rafforza ulteriormente la protezione, obbligando i browser ad accedere solo in modalità cifrata.

4.3.3 Logging e monitoraggio

Monitorare il traffico e le attività del sistema è fondamentale per individuare anomalie e comportamenti sospetti. Un buon sistema di logging deve:

- Registrare accessi, modifiche critiche, errori e fallimenti di autenticazione.
- Includere informazioni come timestamp, indirizzo IP, user agent e ID utente.
- Prevedere la conservazione dei log in modo sicuro e l'accesso solo da parte di personale autorizzato.

Il monitoraggio attivo (es. tramite SIEM) consente inoltre di generare allarmi in tempo reale, facilitare l'analisi post-incidente e contribuire alla conformità normativa (es. GDPR).

4.3.4 Segmentazione e architetture Zero-Trust

La segmentazione di rete consiste nel dividere l'infrastruttura in zone isolate (es. front-end, database), con regole di accesso rigorose tra le zone.

Questo approccio limita la superficie d'attacco e impedisce che un'intrusione in una parte del sistema comprometta l'intera rete.

Il modello *Zero Trust* parte dal principio che nessun dispositivo, utente o applicazione sia automaticamente attendibile, nemmeno all'interno della rete aziendale.

L'accesso viene concesso solo previa autenticazione forte, autorizzazione e verifica continua del comportamento.

L'adozione di architetture Zero Trust rappresenta una tendenza crescente nella sicurezza moderna, soprattutto in ambienti cloud e distribuiti.

4.4 Politiche organizzative di sicurezza

La sicurezza informatica non può basarsi esclusivamente su soluzioni tecnologiche.

È altrettanto fondamentale sviluppare e attuare politiche organizzative efficaci, che coinvolgano l'intera struttura aziendale.

Una politica di sicurezza ben definita crea un quadro chiaro di responsabilità, comportamenti attesi, processi e misure da adottare per prevenire, rilevare e rispondere agli incidenti di sicurezza.

4.4.1 Politiche di sicurezza aziendale

Le politiche di sicurezza definiscono le regole generali che tutti i dipendenti, collaboratori e fornitori devono seguire e includono:

- Uso accettabile delle risorse informatiche (es. vietare installazioni non autorizzate).
- Obblighi di protezione delle credenziali e uso di password sicure e uniche.
- Norme sull'uso di dispositivi personali.
- Restrizioni all'accesso fisico e logico ai sistemi.
- Regole per la gestione e la protezione dei dati sensibili.

Queste politiche devono essere formalizzate in documenti accessibili e aggiornati, distribuiti a tutto il personale, e accompagnati da sessioni formative obbligatorie.

4.4.2 Formazione e consapevolezza

Gli utenti rappresentano spesso l'anello più debole nella catena della sicurezza.

L'errore umano, come cliccare su link di phishing, usare password deboli o condividere dati senza precauzioni, può compromettere anche il sistema più protetto.

Per questo motivo, è essenziale attivare programmi di formazione periodica sulla sicurezza informatica, che aiutino i dipendenti a:

- Riconoscere le minacce comuni (es. email sospette, social engineering).
- Applicare comportamenti corretti nella gestione dei dati.

- Comprendere l'importanza della segnalazione tempestiva degli incidenti.

Le campagne di sensibilizzazione devono essere continue e aggiornate con esempi pratici e attuali.

4.4.3 Gestione delle identità e degli accessi (IAM)

Un buon controllo degli accessi è alla base della sicurezza organizzativa, infatti la gestione delle identità e degli accessi prevede:

- La creazione di account univoci per ogni utente.
- La concessione di privilegi minimi (principio del *least privilege*).
- La revoca tempestiva degli accessi non più necessari.
- La tracciabilità delle attività attraverso audit log.
- La modifica periodica delle credenziali.
- L'imposizione di requisiti minimi di complessità delle password.

Strumenti IAM moderni consentono anche l'autenticazione federata (es. Google), il provisioning automatico degli utenti e il monitoraggio continuo delle anomalie.

4.4.4 Gestione delle patch e aggiornamenti

Molte violazioni di sicurezza avvengono sfruttando vulnerabilità già note e per le quali sono disponibili aggiornamenti correttivi.

Una politica efficace di gestione delle patch deve prevedere:

- Un inventario aggiornato di software, sistemi e dispositivi in uso.
- La valutazione continua delle vulnerabilità note (CVE).
- L'automazione del processo di aggiornamento quando possibile.
- La verifica e il *testing* delle patch prima del *deployment* in ambienti critici.

Questa attività deve essere fatta ciclicamente e essere ben documentata.

4.4.5 Piano di risposta agli incidenti

È fondamentale disporre di un piano di risposta agli incidenti (*Incident Response Plan*)

- La definizione dei ruoli e responsabilità in caso di incidente.
- Le procedure per la rilevazione, contenimento, analisi e ripristino.
- La documentazione dettagliata degli eventi e delle azioni intraprese.
- Le attività *post-incident* per analizzare gli eventi e migliorare i processi futuri.

Un IRP ben progettato e testato regolarmente riduce l'impatto degli incidenti e accelera il ritorno alla normalità.

Capitolo 5 – Caso studio: analisi cliente dell'azienda ospitante

5.1 Presentazione dell'azienda e del sistema informativo

Neboola Srl è una realtà tecnologica innovativa, che fornisce soluzioni in ambito cloud e cybersecurity.

Durante il mio periodo di tirocinio, ho avuto l'opportunità di analizzare l'infrastruttura e un report VA/PT di un loro cliente nel settore e-commerce.

Si tratta di un'azienda operante a livello europeo, con decine di milioni di euro di fatturato annuale, che gestisce una piattaforma e-commerce ad alta disponibilità.

L'infrastruttura del cliente è ospitata interamente su AWS e utilizza un'architettura a microservizi basata su *container*, progettata per garantire scalabilità, resilienza e sicurezza.

Questo approccio consente una gestione dinamica delle risorse e una rapida risposta alle esigenze del mercato.

5.2 Analisi dell'architettura web: componenti e servizi esposti

L'architettura web è distribuita e basata su servizi cloud gestiti, con componenti interconnessi che coprono sia la parte *frontend* sia il *backend*.

Tra i principali elementi architetturali si trovano:

- **Application Load Balancer (ALB):** esposto su internet, funge da punto di ingresso al traffico HTTP/S e bilancia le richieste verso i *container*.
- **Frontend Applicativo:** ospitato su cluster Kubernetes (EKS), gestisce la logica di interfaccia utente e comunicazione con i microservizi.

- **Servizi di Backend:** anch'essi containerizzati in EKS, offrono funzionalità core come catalogo prodotti, gestione ordini e pagamenti.
- **Servizi di caching:** utilizzati per migliorare le performance e ridurre il carico sui sistemi di backend, spesso basati su Redis o Memcached gestiti da AWS.
- **Database relazionali:** basati su Amazon RDS, garantiscono affidabilità, scalabilità e replica automatica.
- **Sistemi esterni on-premise:** il sistema ERP aziendale è ancora mantenuto in sede e integrato tramite API e VPN con la piattaforma cloud.

Questa infrastruttura ibrida consente una forte integrazione tra il mondo cloud e i sistemi legacy, mantenendo al tempo stesso alti standard di sicurezza e disponibilità.

5.3 Identificazione di minacce dell'infrastruttura del cliente

SINTESI DEI RISULTATI

La verifica di sicurezza effettuata ha rilevato un livello complessivo di criticità: **Alto**.

Contesto	Criticità delle vulnerabilità			
	Critica	Alta	Media	Bassa
Totale	0	1	3	2
Applicativo	0	1	3	2
Infrastrutturale	0	0	0	0

Tabella 1: Sintesi vulnerabilità.

Di seguito la lista delle vulnerabilità rilevate con il rispettivo livello di criticità.

ID	Vulnerabilità	Livello criticità	Rilevabile senza Whitelist?
V1	Sensitive Data Disclosure	ALTO	SI
V2	Cookie Attribute Issue	MEDIO	SI
V3	Information Disclosure	MEDIO	SI
V4	User Enumeration	MEDIO	SI
V5	Missing Content Security Policy	BASSO	SI
V6	Missing Permissions-Policy	BASSO	SI

Tabella 2: Lista delle vulnerabilità.

L'analisi delle minacce emerso dal VA/PT, redatto dall'azienda MGALABS, ha evidenziato diverse aree critiche che potrebbero compromettere la sicurezza e la

continuità del servizio, con un totale di sei vulnerabilità identificate: una ad alta criticità, tre a media e due a bassa.

Le vulnerabilità emerse dal VA/PT sono:

- **Sensitive Data Disclosure** (ALTO): la presenza di dati sensibili esposti rappresenta una minaccia critica per la privacy degli utenti e la conformità a normative come GDPR.
Questa vulnerabilità è rilevabile senza *whitelist*, quindi esposta a chiunque navighi sul sito.
- **Cookie Attribute Issue** (MEDIO): la mancata configurazione corretta degli attributi di sicurezza nei cookie (con HttpOnly) può esporre l'applicazione ad attacchi di session hijacking o XSS per compromettere i cookie dell'utente. .
- **Information Disclosure** (MEDIO): la pubblicazione involontaria di informazioni di sistema e delle tecnologie usate può aiutare un attaccante a profilare l'applicazione e condurre attacchi mirati.
- **User Enumeration** (MEDIO): consente a un attore malevolo di determinare la validità di nomi utente, potenzialmente utile per attacchi di brute-force.
- **Missing Content Security Policy e Permissions Policy** (BASSO): la *Content Security Policy* (CSP) è un meccanismo di sicurezza creato per proteggere le applicazioni da vari tipi di attacchi.
CSP definisce le risorse che possono essere caricate da una web application e che il browser può caricare, questo permette di impedire il caricamento di risorse malevole in seguito ad una vulnerabilità presente sulla web application.

Queste vulnerabilità, unite alle minacce che non sono controllabili (perdita di dati, DDoS, scraping da parte dei concorrenti e misconfigurazioni), evidenziano la necessità di un approccio multilivello alla sicurezza che includa la componente applicativa e infrastrutturale.

5.4 Contromisure adottate o consigliate nel VA/PT

Alla luce delle vulnerabilità individuate e delle minacce complessive rilevate, all'azienda cliente è stato consigliato di implementare una serie di contromisure tecniche e organizzative volte a ridurre potenziali attacchi.

- **Sensitive Data Disclosure:** è stata corretta da Neboola Srl prima della consegna del VA/PT dal momento che rappresentava una grave minaccia.

La risoluzione presente nel report consiglia di esporre solamente i dati realmente necessari, utilizzando un principio di least privilege

- **Cookie Attribute Issue:** si suggerisce di utilizzare l'attributo "HttpOnly" all'atto dell'impostazione di un cookie da parte della web application.

L'attributo "HttpOnly" impedisce che il cookie possa essere utilizzato tramite linguaggi di scripting, come Javascript

- **Information Disclosure:** la soluzione è non fornire nessuna pagina di risposta o inserire commenti contenenti informazioni tecnologiche dettagliate nella web application

- **User Enumeration:** viene suggerito di limitare le informazioni restituite dalla webapp come nel caso del form di registrazione che restituisce la presenza o meno di un utenza



- **Header di sicurezza mancanti:** per questa vulnerabilità viene consigliato di utilizzare
 - a. L'header CSP nelle risposte del web server in base al funzionamento e alle risorse richiamate dall'applicazione
 - b. L'header Permissions-Policy in base a quali funzionalità si vogliono abilitare per una maggiore sicurezza e privacy degli utenti.

Parallelamente, restano attive le seguenti misure trasversali già predisposte in risposta a minacce più ampie:

- Backup e Disaster Recovery per la continuità operativa e la protezione dei dati.
- Vulnerability Assessment e Penetration Test periodici per garantire un monitoraggio continuo.
- Utilizzo di una CDN e *Web Application Firewall* (WAF) per mitigare attacchi DDoS, injection, scraping e tentativi di exploit applicativi.
- Bot Management (funzionalità avanzata del WAF) per rilevare e bloccare traffico automatizzato indesiderato.

L'adozione continua di queste misure ha contribuito a rafforzare in modo significativo la postura di sicurezza complessiva dell'organizzazione.

L'approccio adottato, orientato alla prevenzione e al monitoraggio continuo, consente di affrontare tempestivamente eventuali nuove vulnerabilità, garantendo la resilienza dei servizi e la protezione dei dati aziendali e degli utenti nel tempo.

Capitolo 6 – Conclusioni

La trasformazione digitale e la diffusione del commercio elettronico rendono la sicurezza informatica una priorità strategica per le aziende.

In questo elaborato ho analizzato i principali rischi che interessano i siti e-commerce, le vulnerabilità più frequenti e le contromisure tecniche e organizzative adottabili, con un focus specifico sui *Web Application Firewall*.

Attraverso il caso studio analizzato, è stato possibile osservare l'applicazione concreta di strumenti e metodologie apprese, verificando l'efficacia di un approccio proattivo alla protezione dei dati e alla continuità operativa.

La possibilità di visionare un VA/PT reale condotto da professionisti di MGALABS su un cliente mi ha dato l'opportunità di osservare da vicino come vengono individuate e classificate le vulnerabilità in un contesto produttivo, aiutandomi a collegare la teoria appresa in aula alla pratica sul campo.

Il corso IFTS Cyber Security Specialist 3 ha rappresentato un'esperienza formativa completa, che ha unito teoria e pratica, fornendomi le competenze fondamentali per affrontare con metodo e consapevolezza le sfide della cybersecurity.

Grazie a questo percorso, ho rafforzato il mio interesse per la sicurezza informatica e acquisito gli strumenti necessari per proseguire in questo ambito professionale.

Capitolo 7 – Esperienza del tirocinio e valutazione del percorso formativo

7.1 Attività svolte durante lo stage

Durante il periodo di tirocinio, ho avuto l'opportunità di operare in un contesto aziendale dinamico e orientato alle infrastrutture IT in ambienti cloud, utilizzando amazon cloud.

Le principali attività si sono concentrate sull'uso di strumenti di Infrastructure as Code (IaC), in particolare Terraform, con il quale ho sviluppato un progetto per la gestione e l'automazione della configurazione di un'organizzazione su GitHub, migliorando l'efficienza e la tracciabilità delle risorse.

Parallelamente, ho introdotto l'utilizzo di Kubernetes per la gestione di container e microservizi, studiando i concetti fondamentali ed eseguendo il deploy di ambienti di test.

Un altro strumento fondamentale è stato Ansible, che ho utilizzato per automatizzare l'installazione di pacchetti, la configurazione di server in cloud e l'esecuzione di attività ripetitive da remoto, migliorando la coerenza e l'efficienza delle operazioni sistemiche.

Mi è stata inoltre data la possibilità di visionare un report di Vulnerability Assessment e Penetration Test (VA/PT) reale, condotto da professionisti su un cliente.

Questa esperienza mi ha permesso di osservare direttamente come vengono individuate, classificate e descritte le vulnerabilità in un contesto produttivo, offrendomi un collegamento concreto tra quanto appreso in aula e l'applicazione in ambienti reali.

Queste attività mi hanno permesso di sviluppare un approccio orientato alla cultura DevOps, comprendendo l'integrazione tra automazione, sicurezza e affidabilità dei sistemi, e rafforzando la mia capacità di operare con attenzione sia agli aspetti tecnici che a quelli legati alla protezione delle infrastrutture.

7.2 Conoscenze e competenze acquisite in aula e in azienda

Il corso IFTS ha fornito una base tecnica ampia e solida nell'ambito della sicurezza informatica, partendo dai principi fondamentali della protezione dei sistemi informativi, approfondendo la sicurezza delle reti, la gestione delle vulnerabilità, l'analisi dei rischi e il rispetto delle normative.

In aula ho anche approfondito strumenti come Wireshark, Burp Suite, Nessus e concetti chiave come il modello CIA, il risk assessment e la gestione degli incidenti.

In azienda, ho integrato queste conoscenze con competenze pratiche nell'ambito della sicurezza delle infrastrutture cloud-native.

L'uso di Terraform e Ansible mi ha permesso di comprendere le problematiche reali legate all'automazione, alla scalabilità e alla protezione dei servizi distribuiti.

Ho inoltre migliorato le mie capacità di lavorare in team, utilizzare strumenti di versionamento come Git, e applicare pratiche di sicurezza in ambienti reali.

7.3 Valutazione personale del corso IFTS Cyber Security Specialist 3

Il corso si è rivelato estremamente formativo e coerente con le esigenze del mercato del lavoro.

Ho apprezzato in particolare la qualità dei docenti e la possibilità di confrontarmi con professionisti del settore.

Le attività laboratoriali hanno consolidato l'apprendimento in modo efficace.

La possibilità di confrontarmi con professionisti e di affrontare un tirocinio in azienda ha rappresentato un valore aggiunto fondamentale, portandomi a comprendere in modo diretto le esigenze del mondo lavorativo e a migliorare le mie competenze trasversali, come la gestione del tempo, la comunicazione e il problem solving.

L'unica osservazione che mi sento di fare riguarda uno sbilanciamento tra teoria e pratica: il percorso ha dato ampio spazio alla parte teorica, mentre le occasioni di applicazione pratica sono state più limitate.

7.4 Impatto del corso sul mio percorso professionale

Grazie a questo percorso, ho avuto un impatto significativo sul mio sviluppo professionale.

Ho potuto approfondire le principali tematiche legate alla sicurezza informatica, comprendendo come proteggere reti, sistemi e applicazioni attraverso metodologie strutturate e strumenti adeguati.

Il corso mi ha fornito una visione completa delle minacce attuali e delle contromisure più efficaci, aiutandomi a sviluppare competenze tecniche ma anche un approccio analitico e metodico alla gestione dei rischi.

Attraverso le attività pratiche svolte in aula e in azienda, ho imparato a riconoscere le vulnerabilità, a progettare strategie di difesa e ad operare con maggiore consapevolezza in scenari reali.

Il corso ha rappresentato un vero e proprio trampolino di lancio, offrendo strumenti concreti e un mindset critico e proattivo per affrontare con sicurezza il mondo della cybersecurity.

Capitolo 8 – Bibliografia e sitografia

- OWASP Foundation. OWASP Top Ten Web Application Security Risks.
<https://owasp.org/www-project-top-ten/>
- MITRE Corporation. CVE - Common Vulnerabilities and Exposures.
<https://www.cve.org/>
- Cloudflare Web Application Firewall (WAF) documentation.
<https://developers.cloudflare.com/waf/>
- Neboola Srl. Report VA/PT cliente e-commerce.
- Slide e materiali del corso IFTS Cyber Security Specialist 3, a.a. 2024/2025.